

POLÍTICA DE SEGURANÇA CIBERNÉTICA E DA INFORMAÇÃO

FOLHA DE CONTROLE INTERNO

POLÍTICA DE SEGURANÇA CIBERNÉTICA E DA INFORMAÇÃO	
Criação	04/12/2025
Última atualização	04/12/2025
Versão vigente	1.0
Motivo atualização	Elaboração
Classificação da Informação	Interna
Responsável Operacional	Data Protection Officer Diretoria Empresas do Grupo AZ Gestores do Grupo AZ
Responsável Tático	Data Protection Officer
Responsável Estratégico	Alta Direção do Grupo (CEO)
Documentos relacionados	Política de Governança de Dados Todos os procedimentos criados para proteção de dados

POLÍTICA DE SEGURANÇA CIBERNÉTICA E DAS INFORMAÇÕES

1. GLOSSÁRIO

Ameaça. Qualquer causa potencial, interna ou externa, intencional ou não, de um incidente indesejado e que pode resultar em impacto nos objetivos do negócio.

ANPD. A Autoridade Nacional de Proteção de Dados Pessoais.

Controle Interno. Recurso ou medida que assegure formas de tratamento de riscos. A implantação e manutenção adequada de controles materializa a segurança das informações. Podem ser interpretados como controles, por exemplo, políticas, processos, estruturas organizacionais, técnicas padrões, software, hardware e outros.

Dados Pessoais. São informações que se referem a uma pessoa natural identificada ou identificável. Esses dados incluem informações como nome, endereço, número de telefone, endereço de e-mail e outros que permitam a identificação direta ou indireta de um indivíduo.

Dados Pessoais Sensíveis. São dados pessoais que a LGPD definiu assim, a origem racial ou étnica, crenças religiosas, opiniões políticas, filiação a sindicatos, dados de saúde, vida sexual, genética e informações biométricas, quando relacionados a um indivíduo.

Dados Anonimizados. Dados que não podem ser usados para identificar uma pessoa específica, mesmo quando combinados com outras informações.

Dados Pseudonimizados. É uma camada de segurança para que os dados não possam ser atribuídos a um indivíduo sem o uso de informações adicionais, mantidas separadamente.

Gestor. Pessoa que exerce cargo de liderança.

IDS/IPS. É um Sistema de Detecção de Intrusões (IDS) e um Sistema de Prevenção de Intrusões (IPS).

Informação. Qualquer conjunto organizado de dados que possua algum propósito e valor para o sistema do GRUPO AZ, seus clientes, parceiros e colaboradores. A informação pode ser de propriedade da empresa, estar sob sua custódia ou sob custódia de terceiros, como exemplo, informações armazenadas em nuvem.

LGPD. A Lei Geral de Proteção de Dados Pessoais, Lei Federal n. 13.709/2018.

Política de Segurança Cibernética e da Informação. Estrutura de documentos formada pela política, normas e padrões de segurança cibernética e segurança da informação.

Recursos. Qualquer ativo, tangível ou intangível, pertencentes, a serviço ou sob responsabilidade do GRUPO AZ, que possua valor para a empresa. Podem ser considerados recursos: pessoas, ambientes físicos, tecnologias, serviços contratados, em nuvem, sistemas e processos.

Recursos Críticos. Recursos essenciais para o funcionamento da operação do sistema do GRUPO AZ e que possuem informações críticas ou sensíveis.

Segurança Cibernética. Conjunto de tecnologias, processos e práticas projetados para proteger redes, computadores, sistemas e dados de ataques, danos ou acesso não autorizado.

Segurança da Informação. É a proteção das informações, sendo caracterizada pela preservação da confidencialidade, integridade e da disponibilidade dos ativos de informação, através da implementação de controles de segurança da informação.

2. O SISTEMA DE GESTÃO DE SEGURANÇA DA INFORMAÇÃO E SEGURANÇA CIBERNÉTICA DO GRUPO AZ

O GRUPO AZ adota uma abordagem baseada em riscos para proteger seus ativos de informação críticos e as informações confidenciais internas e de clientes contra ameaças prováveis e de alto impacto. Foram incorporadas políticas orientadoras à criação de procedimentos em observância aos princípios de segurança da informação e da privacidade na cultura organizacional, de forma que cada um dos envolvidos nas nossas atividades seja responsável por garantir uma estrutura robusta de segurança da informação e dos dados pessoais.

Caso alguém não entenda completamente quaisquer disposições deste documento, poderá entrar em contato com a Data Protection Officer, Mariana Benjamin Costa, responsável técnica da TALEB BARBOSA ADVOCACIA E CONSULTORIA, sociedade devidamente constituída e inscrita no CNPJ sob o nº 37.984.935/0001-60, com endereço na Rua Barão do Gravataí, 375/403, Bairro Menino Deus, CEP 90050-330, em Porto Alegre/RS, e na Av. Juscelino Kubitschek, 3563, sala 9 - Jardim Imperial, Luís Eduardo Magalhães - BA (a "TBARBOSA"), a Encarregada pelo Tratamento de Dados Pessoais.

3. ESCOPO, OBJETIVO E ABRANGÊNCIA

3.1. Escopo

A presente **Política de Segurança Cibernética e da Informação ("Política")** tem como escopo todos os sistemas de informação operados pelo GRUPO AZ, o que inclui, mas não se limita, à documentação, controles lógicos, recursos humanos, hardware, software e informações. Esta Política concentra as diretrizes de tratamento e proteção de dados, mas não esgota os procedimentos implementados.

3.2. Objetivo

Estabelecer e manter a estrutura destinada à segurança das informações de propriedade e/ou tratadas pelo GRUPO AZ, por meio de políticas, processos e procedimentos condizentes com o porte e o modelo de negócio, observando os Princípios de Segurança da Informação e a Lei Geral de Proteção de Dados (LGPD). Este documento busca, também, orientar a execução das ações relacionadas ao tratamento de dados, pessoais ou não, e o uso adequado de ativos e/ou

informações pelos colaboradores, estagiários, terceiros, fornecedores, parceiros e outras partes envolvidas nos negócios da empresa.

3.3. Abrangência e aplicação

Esta **Política** é aplicável a todos os colaboradores, terceiros e quaisquer outras pessoas, sejam físicas ou jurídicas, que tenham ou venham a ter acesso às **Informações** de propriedade e/ou tratadas pelo GRUPO AZ e afeta todas as áreas de negócios, escritórios e operações da empresa.

Esta **Política** tem aplicação **imediata** a partir da sua publicação e o seu descumprimento será considerado **falta grave**, podendo resultar na aplicação de sanções, incluindo a rescisão imediata do contrato, além de sanções processuais e financeiras.

3.4. Local e disponibilidade

Este documento está disponível para consulta em formato digital no drive da empresa.

3.5. Princípios da segurança da informação

A **Segurança da Informação** baseia-se na “preservação da confidencialidade, integridade e disponibilidade da informação”. Esses três conceitos são considerados como Princípios de Segurança da Informação e devem ser garantidos e respeitados por todos aqueles sujeitos a esta política, considerando os seguintes conceitos:

- **Confidencialidade.** Garantia de que somente pessoas previamente autorizadas e selecionadas terão acesso aos ativos de informação e informações da empresa, protegendo-os contra acessos não autorizados e vazamentos de dados. A confidencialidade estende-se a todos os tipos de dados, especialmente os dados pessoais e sensíveis, assegurando que seu acesso seja restrito conforme as necessidades operacionais e legais.
- **Disponibilidade.** Garantia de que os ativos de informação estejam acessíveis e utilizáveis por indivíduos autorizados sempre que necessário, atendendo aos requisitos operacionais e de continuidade de negócios. A disponibilidade deve ser mantida por meio da implementação de controles robustos, como backups regulares, redundância de sistemas e planos de recuperação de desastres, assegurando a pronta recuperação e o acesso às informações em caso de incidentes.
- **Integridade.** Garantia de precisão, completude, imutabilidade dos dados e a manutenção de sua originalidade e conteúdo, desde a sua criação até o seu descarte, de forma a assegurar a confiabilidade das informações, que somente poderão ser modificadas por pessoas previamente autorizadas, e selecionadas pelo GRUPO AZ.
- **Privacidade.** Garantia de proteção dos dados pessoais dos titulares, em conformidade com as leis e regulamentos aplicáveis, em especial com a Lei Geral de Proteção de Dados (LGPD). Este princípio abrange requisitos específicos de confidencialidade, integridade e disponibilidade, com o objetivo de salvaguardar os direitos dos titulares de dados, minimizando riscos de exposição indevida e assegurando que o tratamento de dados pessoais seja conduzido com transparência, respeito e responsabilidade.

4. ESTRUTURA ORGANIZACIONAL E ATRIBUIÇÕES ESPECÍFICAS

4.1. Responsável pela Alta Direção

O CEO tem como atribuições:

- Prestar o suporte necessário para manutenção desta Política e diretrizes;
- Avaliar continuamente a conformidade desta Política com os objetivos estratégicos dos negócios da AZ; e
- Participar dos treinamentos e ações de conscientização.

4.2. Responsável pela área de tecnologia

A pessoa gestora responsável pela área de tecnologia da informação do GRUPO AZ tem como atribuições:

- Gerir e supervisionar a Segurança da Informação no GRUPO AZ;
- Monitorar e avaliar periodicamente o plano estratégico de Segurança da Informação; e
- Conduzir apurações em caso de suspeita ou ocorrência de incidentes em Segurança da Informação

4.3. Responsável pela área de privacidade

A Data Protection Officer do GRUPO AZ tem como atribuições:

- Gerir e supervisionar a Proteção de Dados Pessoais no GRUPO AZ;
- Monitorar e avaliar periodicamente o plano estratégico de Proteção de Dados Pessoais;
- Conduzir apurações em caso de suspeita ou ocorrência de incidentes de segurança que envolvam dados pessoais, de forma conjunta com a pessoa gestora responsável pela área de tecnologia;
- Ser o elo de comunicação entre os Titulares de Dados Pessoais e o GRUPO AZ;
- Ser o elo de comunicação entre os Controladores de Dados Pessoais e o GRUPO AZ, naquilo que for importante para a definição de tratamentos de dados pessoais;
- Ser o agente de comunicação com a **ANPD**; e
- Disseminar conhecimentos através de ações de conscientização e treinamentos recorrentes e atualização contínua para os **Colaboradores** e **Terceiros** que sejam afetados/afetem o tratamento de dados pelo GRUPO AZ.

4.4. Sócios, colaboradores e prestadores de serviços do GRUPO AZ

Cabe a todos os sócios, colaboradores e prestadores de serviços do GRUPO AZ, inclusive os cooperados:

- Conhecer e cumprir rigorosamente esta **Política**, bem como normas/procedimentos correlatos, especialmente a **Política de Governança de Dados Pessoais**;
- Participar dos treinamentos e ações de conscientização;
- Estar atento e reportar o GRUPO AZ em caso de perceber ou suspeitar práticas em não conformidade com esta **Política**.

5. DIRETRIZES

Esta **Política** estabelece diretrizes para o tratamento de **Informações** no decorrer das atividades dos integrantes do GRUPO AZ. Estas orientações são complementares às instruções e procedimentos padrão de cada setor e unidade de negócios do GRUPO AZ, como forma de garantir a atividade empresarial com a devida proteção das informações.

5.1. Diretrizes Gerais

Para fins desta **Política** ficam estabelecidas as seguintes diretrizes gerais:

Propriedade da Informação: toda informação gerada, adquirida, manuseada, armazenada, transportada e/ou descartada nas dependências e/ou em ativos da empresa deverá ser considerada patrimônio do GRUPO AZ e utilizada exclusivamente para os interesses corporativos.

O acesso à informação deve ser gerenciado: O acesso lógico, o controle de acesso físico e o uso da informação do GRUPO AZ devem ser aprovados, controlados, registrados, armazenados e monitorados, de forma a permitir a adequada execução das tarefas inerentes ao seu cargo ou função. O acesso às informações deve ser restrito às pessoas explicitamente autorizadas e de acordo com a necessidade para o desenvolvimento de suas atividades de trabalho. Deve-se aplicar sempre a regra de mínimo acesso.

Gestão de Incidentes: todos os colaboradores, consultores e prestadores de serviço do GRUPO AZ, em qualquer vínculo, função ou nível hierárquico têm a obrigação de reportar imediatamente quaisquer incidentes de segurança que tomarem conhecimento, de modo que possam ser registrados, avaliados e tratados de acordo com o plano de resposta a incidentes.

Treinamento e Conscientização: deve ser estabelecido programa de conscientização, educação e treinamento, com o objetivo de disseminar a cultura de segurança da informação no GRUPO AZ.

6. POLÍTICAS INTERNAS

6.1. Política de Gerenciamento de Projetos

Os projetos desenvolvidos no âmbito do GRUPO AZ - incluindo iniciativas internas, entregas para clientes, avaliações contratuais, definições de escopo e organização de sprints - devem obrigatoriamente passar por análise e debate prévio do time Tech e da Data Protection Officer antes de sua aprovação final e entrada em produção para avaliar riscos operacionais, tecnológicos, financeiros e jurídicos.

Essa etapa prévia tem como finalidade:

- Verificar alinhamento estratégico com os objetivos e metas do GRUPO AZ;
- Uniformizar critérios de priorização, garantindo que recursos e esforços sejam direcionados de forma eficiente;
- Prevenir impactos negativos decorrentes de incertezas no escopo, nas dependências técnicas ou nas entregas esperadas;
- Assegurar governança, rastreabilidade e transparência em todas as decisões relacionadas a projetos.

Nenhum projeto poderá seguir para desenvolvimento, homologação ou implantação sem a manifestação das áreas responsáveis envolvidas — especialmente Diretoria, Tecnologia, Produto, Privacidade e Operações, conforme aplicável.

6.2. Política de Uso de Dispositivos Móveis

Os AZTechs deverão adotar regras de segurança ao utilizar seus dispositivos pessoais para o trabalho, como:

- O dispositivo deve auto bloquear após 5 minutos de inatividade;
- Dispositivos roteados ou com jailbreak são estritamente proibidos de serem utilizados para trabalho;
- Informar imediatamente o setor de tecnologia/DPO caso se depare com suspeita ou certeza de ocorrência de incidentes cibernéticos, como infecção por vírus, furto, roubo, malware e outros relacionados;
- Somente acessar redes de wi-fi públicas em caso de extrema necessidade;
- Aparelhos perdidos ou roubados deverão ser comunicados à empresa imediatamente e em até 24h;
- Avaliar criticamente as mensagens que receber, em especial quanto à origem, conteúdo e avaliação da urgência e nunca clicar em links ou abrir anexos de e-mails de fontes não confiáveis para evitar phishing;

- Utilizar aparelhos e dispositivos com ética e respeito, em atenção às regras de segurança do GRUPO AZ;
- Ser pessoalmente responsável pelos custos associados com os seus dispositivos pessoais;
- Utilizar sempre a versão mais atualizada do sistema operacional e efetuar todas as atualizações do fabricante;
- Não utilizar logins pessoais para qualquer tarefa relacionada o GRUPO AZ;
- Manter os ambientes pessoal e de trabalho separados, na medida do possível, evitando o compartilhamento do dispositivo ao máximo, inclusive para membros da família;
- Não instalar aplicativos não oficiais ou não autorizados pela empresa;
- colaborador é corresponsável pela manutenção da segurança dos dados do GRUPO AZ em seus dispositivos pessoais, devendo observar rigorosamente esta Política. A inobservância das regras aqui previstas poderá acarretar responsabilização disciplinar e, quando aplicável, civil e/ou contratual; e
- É obrigatório participar dos treinamentos de segurança promovidos periodicamente pela Data Protection Officer. Sem o acompanhamento dos treinamentos, o colaborador não poderá utilizar dispositivos BYOD.

É **proibido** usar os dispositivos pessoais para:

- Armazenar ou transmitir materiais ilícitos;
- Armazenar ou transmitir informações confidenciais do GRUPO AZ;
- Assediar / perseguir pessoas;
- Armazenar dados relacionados à propriedade intelectual, segredos industriais e informações comerciais do GRUPO AZ;
- Os dados relacionados à propriedade intelectual, segredos industriais e informações comerciais devem ser armazenados diretamente na nuvem do GRUPO AZ; e
- É proibido realizar o download de quaisquer informações, arquivos, documentos e/esquemas ou projetos na máquina pessoal, bem como quaisquer dados que possam ser de titularidade, propriedade ou interesse do GRUPO AZ para fins particulares.

6.3. Política de Teletrabalho

Nossa empresa trabalha em regime de teletrabalho. Isso significa que as pessoas podem utilizar dispositivos fixos ou móveis, em redes públicas ou privadas, em qualquer localidade. A segurança das informações e a proteção dos dados pessoais são fundamentais para a manutenção da nossa política de teletrabalho. Nós não recomendamos a utilização de cafés, restaurantes, aeroportos, hotéis e coworkings para realizar atividades que possam envolver:

- Alto tráfego de dados confidenciais;
- Acesso a bancos de dados;
- Troca de informações confidenciais; ou
- Outras situações que, pela sua natureza, possam trazer a necessidade de maiores cuidados.

Todas as nossas áreas de negócio são acessíveis remotamente, mas é importante que você entenda que isso não significa que devam ser acessadas quando houver suspeita de ou ocorrência de algo que possa diminuir a sua segurança ou de qualquer modo aumente nossa percepção de risco.

6.4. Política de Contratação e Gestão de Recursos Humanos

6.4.1. Antes da contratação

Sempre que necessário, a depender do cargo a ser preenchido, o candidato deverá ser avaliado também quanto aos seus conhecimentos e potenciais de resiliência quanto aos temas de privacidade e segurança da informação, bem como poderão ser consultadas bases oficiais públicas para análise de background.

Importante: a consulta não envolverá análise de crédito, mas tão somente comportamental, em fontes públicas.

6.4.2. Na contratação

O profissional contratado deverá receber cópia das políticas internas e demais documentos publicados pelo GRUPO AZ e assinar um Aviso de Privacidade interno e Termo de Responsabilidade, atestando ciência em relação à obrigação de cumprimento das disposições estabelecidas nestes documentos.

6.4.3. Na vigência do contrato

Devem ser realizadas ações de conscientização de forma periódica.

Metas de privacidade e segurança da informação poderão ser previstas para fins de promoção, acesso a determinados cargos etc.

Sempre que houver atualização ou publicação de novas políticas, os AZTechs devem receber uma cópia (física ou digital) em relação a esses novos documentos. A entrega deve ser feita com termo de aceite ou mediante disponibilização em local de acesso facilitado e de forma continuada.

6.4.4. Na rescisão

A depender do cargo do AZTech, poderá ser solicitada a assinatura de Termo de Desligamento para que se comprometa a eliminar todas as cópias de dados e documentos contendo dados pessoais de clientes, ou seus representantes, outros funcionários e fornecedores que,

eventualmente, mantenha em seus dispositivos pessoais (celulares, tablets, computadores etc.) e tenha obtido em razão do seu trabalho.

Deve ser garantido que todos os ativos da empresa que estavam em posse do AZTech, como equipamentos, mídias, documentos, tokens de acesso, entre outros, sejam devolvidos.

Deve ser realizada a remoção dos acessos de sistemas e plataformas da empresa antes da comunicação do desligamento.

6.5. Política de Gestão de Identidades, controle e gerenciamento de acessos

Para acesso dos dados e sistema interno do GRUPO AZ, é obrigatório o uso de uma única identificação (*login*) e de senha de acesso, fornecidos pelo Setor de Tecnologia quando dos procedimentos de contratação e onboarding.

As permissões de acesso do AZTech devem ser definidas pelo gestor, estando a escolha limitada às necessidades das atividades efetivamente realizadas pelo AZTech. Sempre que necessário, poderão ser conferidas outras autorizações, desde que previamente autorizadas e solicitadas pelo gestor da área ao time de Tecnologia, com a estrutura básica assim resumida:

Tipo	Exemplo	Regras
Operacional	Usuários comuns	Privilégios mínimos
Administrativo	Gestores	Acesso apenas ao necessário
Privilegiado	root/admin	Acesso excepcional e controlado

Após o encerramento das atividades do AZTech, seus acessos deverão ser bloqueados imediatamente em todos os sistemas internos e externos utilizados pelo GRUPO AZ. Caso necessário, clientes, terceiros e fornecedores deverão ser imediatamente avisados.

Todos os *logins* e senhas são, obrigatoriamente, de uso **pessoal e intransferível**, sendo proibida a sua divulgação, sob pena de serem bloqueados quando constatada eventual irregularidade.

O padrão adotado para o formato da conta de acesso do AZTech deverá ser:

Login	e-mail corporativo único e exclusivo
Senha	No mínimo 8 caracteres, contendo pelo menos um caractere numérico, uma letra maiúscula e um caractere especial.

Ainda que a ferramenta utilizada não possua as condições de configuração de acesso e política de gestão de senhas, os AZTech observarão estas regras para conferir maior segurança da informação aos ativos.

Todos os acessos devem ser imediatamente bloqueados quando se tornarem desnecessários, como no caso de mudança de função ou rescisão do contrato.

Gestores devem revisar acessos periodicamente.

Nenhum AZTech ou Terceiro poderá ter acesso às senhas cadastrais de qualquer AZTech, Terceiro ou outro usuário. Os logins e senhas devem ser pessoais e intransferíveis.

6.6. Política de Senhas e Autenticação

Deverá ser obedecido o padrão de expiração de no máximo 180 (cento e oitenta) dias, habilitação de autenticação multifatorial sempre que possível e, na medida do possível, a participação em eventuais treinamentos sobre a importância da definição de senhas consideradas fortes.

É proibido adotar:

- Contas compartilhadas;
- Senhas em papel de fácil acesso por terceiros;
- Envio de senhas por WhatsApp, e-mail ou print.

6.7. Política de Hardening

A presente Política de Hardening estabelece diretrizes, requisitos mínimos e práticas progressivas para o endurecimento ("hardening") dos ativos tecnológicos do GRUPO AZ, com o objetivo de reduzir superfícies de ataque, fortalecer a resiliência operacional e assegurar a proteção dos ativos de informação, em observância à LGPD, aos princípios de Segurança da Informação e às recomendações identificadas nos processos de auditoria interna e externa.

Dada a atual maturidade tecnológica da organização, esta Política adota abordagem escalonada, priorizando controles administrativos, de configuração mínima e de evolução gradual, sem prejuízo do compromisso permanente de melhoria contínua.

Esta Política aplica-se a todos os ativos tecnológicos utilizados no GRUPO AZ, incluindo, mas não se limitando a dispositivos corporativos e pessoais utilizados sob regime BYOD, estações de trabalho, notebooks, tablets e dispositivos móveis, servidores locais e serviços em nuvem, aplicações internas e externas, APIs, endpoints e integrações de terceiros e infraestrutura de rede e serviços expostos à Internet.

O hardening no GRUPO AZ fundamenta-se nos seguintes princípios:

6.7.1. Princípio da Progressividade

Diante de limitações técnicas e orçamentárias, o GRUPO AZ implementa endurecimento de forma progressiva, priorizando controles essenciais, imediatos e viáveis.

6.7.2. Princípio da Redução de Superfície de Ataque

Todos os ativos devem operar com o mínimo necessário de portas, permissões, serviços, acessos e softwares.

6.7.3. Princípio do Menor Privilégio

Todos os acessos são concedidos apenas conforme estrita necessidade funcional, sendo proibido o uso de privilégios administrativos por usuários comuns.

6.7.4. Princípio da Melhoria Contínua

As diretrizes aqui previstas serão revisadas e ampliadas periodicamente, acompanhando evolução tecnológica, riscos identificados e recomendações da auditoria.

O hardening dos ambientes do GRUPO AZ está disciplinado, de forma transversal, nas seções “Política de Hardening”, “Política de Gestão e Proteção de Endpoints”, “Política de Proteção contra Códigos Maliciosos”, “Política de Prevenção e Detecção de Intrusão” e “Política de Gestão de Vulnerabilidades”, contemplando desativação de serviços desnecessários, aplicação de patches, bloqueio de portas, uso de EDR, firewall e demais mecanismos de proteção em camadas.

6.8. Política de Gestão de Ativos

A Gestão de Ativos do GRUPO AZ tem por objetivo assegurar que todos os ativos de informação sejam conhecidos, inventariados, classificados e adequadamente protegidos ao longo de todo o seu ciclo de vida, em alinhamento com esta Política de Segurança Cibernética e da Informação, com a Política de Governança de Dados Pessoais e com a Política de Classificação da Informação.

6.8.1. Inventário de Ativos

Todos os ativos de informação do GRUPO AZ devem constar em inventário mantido pelo setor de Tecnologia, com apoio dos Gestores da Informação e demais áreas responsáveis. Para fins desta Política, são considerados ativos, entre outros:

- equipamentos (notebooks, desktops, tablets, smartphones corporativos);
- componentes de infraestrutura e rede;
- servidores locais e ambientes em nuvem;
- sistemas, aplicações, APIs e bancos de dados;
- informações e conjuntos de dados (inclusive dados pessoais);
- softwares licenciados e serviços em nuvem utilizados pelo GRUPO AZ.

O inventário deve conter, no mínimo, identificação do ativo, proprietário, localização (física ou lógica), critério de criticidade e status (ativo, em manutenção, descomissionado).

6.8.2. Identificação e Registro

Cada ativo deve possuir identificação única que permita o seu rastreamento e vinculação ao respectivo proprietário.

Sempre que um novo ativo for adquirido, contratado ou colocado em operação, o responsável técnico deverá:

- providenciar sua inclusão no inventário;
- associá-lo ao Gestor da Informação ou área responsável;
- registrar sua finalidade principal de uso.

Da mesma forma, ativos desativados, substituídos, descartados ou transferidos devem ter seu status atualizado no inventário.

6.8.3. Classificação e Criticidade

A classificação das informações associadas a cada ativo observará os critérios de confidencialidade, integridade, disponibilidade, autenticidade e privacidade definidos na Política de Classificação da Informação, bem como os níveis de impacto ali descritos.

A criticidade do ativo deve considerar, de forma combinada:

- a classificação das informações que ele trata, armazena ou transmite;
- o impacto de sua indisponibilidade para a operação do GRUPO AZ;
- a relevância regulatória, contratual ou de negócio associada ao seu uso.

A partir dessa avaliação, poderão ser definidas prioridades de proteção, controles adicionais e requisitos mínimos de segurança, em especial para ativos classificados como críticos.

6.8.4. Propriedade e Responsabilidades

Todo ativo deve ter um proprietário formalmente designado (pessoa ou área), responsável por:

- zelar pela atualização dos registros no inventário;
- solicitar e acompanhar a aplicação de medidas de segurança compatíveis com a criticidade do ativo;
- apoiar avaliações de risco e, quando aplicável, planos de tratamento de vulnerabilidades;
- comunicar ao setor de Tecnologia alterações relevantes, desuso ou descomissionamento.

O proprietário do ativo atuará em conjunto com o setor de Tecnologia e com a DPO sempre que o ativo envolver tratamento de dados pessoais.

6.8.5. Manutenção e Atualização do Inventário

O inventário de ativos deve ser atualizado sempre que houver:

- aquisição ou contratação de novos ativos;
- substituição, realocação ou alteração relevante de configuração;
- descomissionamento, descarte ou devolução de ativos;
- mudanças de propriedade ou de área responsável.

As atualizações devem ser registradas de forma tempestiva, de modo que o inventário reflita a situação real dos ativos utilizados pelo GRUPO AZ.

6.8.6. Revisões Periódicas

Deve ser realizada revisão periódica do inventário de ativos, em periodicidade definida pelo setor de Tecnologia, preferencialmente de forma alinhada ao ciclo de auditorias internas de segurança da informação.

As revisões deverão verificar a existência física ou lógica dos ativos inventariados, identificar ativos em uso que não estejam registrados, confirmar se as informações de propriedade, classificação e criticidade permanecem válidas, corrigir discrepâncias ou inconsistências identificadas.

Eventuais desvios relevantes identificados nas revisões poderão originar planos de ação específicos e, quando pertinente, ser reportados no âmbito dos indicadores de segurança da informação previstos no Anexo desta Política.

6.8.7. Uso aceitável de ativos

Informações de propriedade do GRUPO AZ armazenadas em dispositivos eletrônicos e computadores permanecem como propriedade exclusiva do Grupo AZ, ainda que o dispositivo eletrônico ou computador seja de propriedade do AZTech.

O AZTech deverá comunicar prontamente o roubo, furto e a certeza ou suspeita de perda de equipamentos utilizados para a prestação de serviços para o GRUPO AZ, assim como a divulgação não autorizada de informações.

Para fins de segurança e manutenção de rede, pessoas autorizadas pelo GRUPO AZ podem monitorar equipamentos cedidos pelo GRUPO AZ que forem utilizados por AZTech para prestar serviços para o GRUPO AZ, além de sistemas e tráfego de rede a qualquer momento, de acordo com esta política.

6.8.8. Uso inaceitável de ativos

As seguintes atividades são estritamente proibidas, sem exceções:

- Violações dos direitos de qualquer pessoa ou empresa protegidos por direitos autorais, segredos comerciais, patentes ou outras leis ou regulamentos de propriedade

intelectual semelhantes, incluindo, mas não se limitando à instalação ou distribuição de produtos de software "pirateados" ou outros produtos de software que não estão devidamente licenciados para uso pelo GRUPO AZ, na condução das atividades da empresa.

- Exportar software, informações técnicas ou tecnologia em violação da legislação aplicável.
- Introdução de programas maliciosos na rede ou no servidor (por exemplo, vírus, worms, cavalos de Tróia, ransomware, etc.).
- Revelar a senha/frase de acesso a outras pessoas ou permitir o uso de sua conta por outras pessoas.
- Usar um ativo de computação para participar ativamente na aquisição ou transmissão de material que esteja em violação das leis de assédio sexual ou ambiente de trabalho hostil.
- Fazer ofertas fraudulentas de produtos, itens ou serviços.
- Causar violações de segurança ou interrupções na comunicação de rede.
- Contornar a autenticação do usuário ou a segurança de qualquer host, rede ou conta.
- Usar qualquer programa/script/comando ou enviar mensagens de qualquer tipo com a intenção de interferir ou desativar a sessão de terminal de um usuário, por qualquer meio, localmente ou via Internet/Intranet/Extranet.
- Fornecer informações sobre ou listas de AZTechs ou clientes a partes externas ao GRUPO AZ.

6.8.9. Cuidados com e-mail profissional

O AZTech deverá seguir as seguintes regras relacionadas ao email profissional:

- Não abrir anexos com as extensões .bat, .exe, .src, .lnk e .com se não tiver certeza absoluta de que solicitou o e-mail. Em caso de dúvida, **não abrir o arquivo** e reportar imediatamente.
- Desconfiar de mensagens com assuntos incomuns, erros de digitação, linguagem incoerente ou enviadas em línguas estrangeiras sem que haja motivo justificável. Verificar com cuidado remetentes desconhecidos ou pequenas variações de domínios (ex.: "@gmail.com" em vez de "@gmail.com"; ou @support-acccounte.com e afins)
- Proibição de interação com conteúdo malicioso, sendo proibido abrir, clicar, baixar, responder ou encaminhar mensagens suspeitas, incluindo:
 - correntes;
 - spam;

- phishing;
 - tentativas de engenharia social;
 - ofertas não solicitadas;
 - mensagens com links encurtados ou mascarados.
- O e-mail fornecido pela empresa não deve ser utilizado para fins pessoais, cadastros externos, newsletters, compras on-line ou qualquer atividade que não esteja diretamente relacionada às responsabilidades profissionais; e
 - Qualquer e-mail duvidoso, anexo suspeito, link estranho ou tentativa percebida de phishing deve ser imediatamente informada à Data Protection Officer (DPO) ou ao canal oficial de segurança. O reporte permite bloqueio, análise forense e mitigação de riscos para todo o GRUPO AZ.

6.9. Política de Classificação da Informação

As informações que são tratadas, manuseadas, operadas e de qualquer forma utilizadas pelo GRUPO AZ, para qualquer finalidade, devem ser classificadas. Essa classificação deve ser norteadas pelos objetivos estratégicos do GRUPO AZ e os requisitos de segurança do Sistema de Gestão de Segurança da Informação: confidencialidade, integridade, disponibilidade, autenticidade e privacidade.

A confidencialidade é o principal critério de classificação da segurança das informações, sendo o sigilo e a restrição de acesso os parâmetros para definição do primeiro nível de classificação das informações. Cabe ao **Gestor da Informação** classificá-la desde o primeiro estágio do ciclo de vida, ou seja, os documentos devem ser classificados na sua emissão ou recepção, sendo certa a necessidade de revisão periódica sobre a classificação imposta – e sempre que julgar necessário.

Caso o **Gestor da Informação** tenha dúvidas sobre a classificação, deverá consultar a pessoa responsável pela área de tecnologia.

Na hipótese de um documento conter informações classificadas em diferentes graus de sigilo ou restrição de acesso, será atribuído ao documento o tratamento do grau de sigilo ou restrição mais elevada.

As cópias devem receber o mesmo nível de proteção do documento original.

Quando uma informação faz parte de um conjunto de informação de propriedade de terceiros, mas está sob guarda do GRUPO AZ, chamamos elas de Informações Custodiadas. Essa condição não exclui o dever de classificação pelo **Gestor da Informação**.

Algumas informações podem precisar ser divulgadas obrigatoriamente, em razão de obrigação legal e/ou normativa de publicação no sítio corporativo do GRUPO AZ na internet ou por orientação estratégica do GRUPO AZ. Em qualquer caso, **ANTES** da divulgação, no entanto, é fundamental avaliar se:

- A informação pode conter segredos comerciais e/ou industriais; e
- A informação pode conter informações pessoais.

Caso a resposta seja “SIM” para qualquer das hipóteses, a informação deve ser submetida à análise prévia do Gestor da Informação e/ou à DPO, se sobre informações pessoais, para validação do impacto à segurança do GRUPO AZ e à privacidade de titulares.

6.9.1. Tipos de Informação

As informações podem ser:

- Informação estratégica: informação de natureza estratégica cuja divulgação pode prejudicar os interesses da organização;
- Informação relevante: informações sobre decisões relevantes de caráter político-administrativo, técnico, negocial ou econômico-financeiro ocorrido ou relacionado aos negócios do GRUPO AZ, que pode influenciar na sua credibilidade;
- Informação pessoal: informação relacionada à pessoa natural, identificada ou identificável, podendo ou não ser uma informação pessoal sensível, considerada aquela relativa à intimidade, vida privada, honra e imagem, e aquelas consideradas sensíveis de acordo com o art. 5º, II, e art. 11 da LGPD..

Analisar o tipo de informação classificada é fundamental para correta rotulagem.

6.9.2. Procedimentos de Classificação

O sigilo é um dos parâmetros básicos para o primeiro nível de classificação das informações. Para definição do nível de proteção, o risco deve ser qualificado com base no nível de impacto geral:

Grau de Sigilo	Critérios para utilização	Impacto
Confidencial	Informações que necessitam de sigilo absoluto. O acesso à informação é limitado às pessoas autorizadas e convém que seja controlado e auditado. Seu tratamento, especialmente o compartilhamento, requer atenção máxima	São de alto valor por motivos estratégicos e/ou informações cuja indisponibilidade e/ou inexatidão poderão causar prejuízos à continuidade dos negócios e/ou com a possibilidade de provocar danos relevantes ao negócio (prejuízos financeiros, legais, contratuais) ou à reputação e imagem da organização

Restrita	Informações referentes a um determinado grupo, áreas ou cargos da organização. O acesso à informação é restrito. Seu tratamento, especialmente seu compartilhamento, requer atenção contínua	São de valor por motivos estratégicos e/ou (informações cuja indisponibilidade e/ou inexatidão poderão causar problemas à continuidade dos negócios e dificuldade na recuperação) e/ou com a possibilidade de provocar danos ao negócio (prejuízos financeiros, legais, contratuais) ou à reputação e imagem da organização. A disponibilidade limitada e o tempo de recuperação em caso de materialização do risco são aceitos
Interna	Informações internas da organização, disponibilizadas aos funcionários e para alguns terceiros com regras de controle. O compartilhamento com prestadores de serviços deve ser criterioso, cauteloso e dentro do melhor interesse da empresa e sempre com a autorização do proprietário da informação	São de baixo valor por motivos estratégicos e/ou (informações cuja indisponibilidade e/ou inexatidão não causam problemas à continuidade dos negócios e dificuldade na recuperação) e/ou com a possibilidade de provocar pequenos danos ao negócio (prejuízos financeiros, legais, contratuais) ou à reputação e imagem da organização
Pública	São informações de conhecimento público e que não possuem restrições de acesso	Informações cuja exatidão e acessibilidade apresentam pouco ou nenhum risco ao negócio. Os usuários aceitam eventuais indisponibilidades e longos períodos para recuperação das informações

As informações devem ser mantidas apenas pelo tempo necessário para cumprir seus objetivos de negócio ou requisitos legais.

O descarte de informações classificadas deve ser realizado de maneira segura, garantindo que não possam ser recuperadas por indivíduos não autorizados. As disposições relacionadas à retenção e descarte de dados pessoais se encontram detalhadas em política específica.

6.9.3. Uso de informações críticas

Todas as informações classificadas devem ser rotuladas de forma clara com a respectiva classificação.

Informações Confidenciais e Restritas devem ser manuseadas de acordo com os procedimentos de segurança especificados, incluindo o uso de ambientes seguros para processamento e armazenamento.

O nível de classificação deve ser revisado periodicamente e ajustado conforme necessário, especialmente em caso de mudanças no contexto ou sensibilidade da informação.

6.9.3.1. Tipos de documentos

- Documento público: documento sem qualquer restrição de acesso ou cuja divulgação está relacionada à conformidade legal; e
- Documento sigiloso: documento que deve ser de conhecimento restrito e, dessa forma, necessita de medidas especiais de segurança para custódia e acesso.

6.10. Política de Monitoramento de Rede

O GRUPO AZ mantém processo contínuo de monitoramento da infraestrutura de rede, dos eventos de segurança e dos principais componentes tecnológicos utilizados na operação, com o objetivo de identificar comportamentos anômalos, prevenir incidentes e preservar a integridade, disponibilidade e confiabilidade dos ativos de informação.

O monitoramento deve observar os seguintes princípios e diretrizes gerais:

- Detecção de Atividades Anômalas: O tráfego de rede, acessos, eventos de autenticação, uso de privilégios e comunicações internas e externas devem ser acompanhados de forma a permitir a detecção antecipada de incidentes, tentativas de intrusão, falhas de configuração ou comportamentos incompatíveis com o uso legítimo dos recursos tecnológicos.
- Registro e Rastreabilidade: Eventos relevantes gerados por dispositivos de rede, firewalls, serviços em nuvem, endpoints e sistemas corporativos devem ser registrados de forma íntegra, com retenção mínima compatível com exigências legais, contratuais e com as recomendações de auditoria vigentes.
- Monitoramento Proporcional à Criticidade: O nível de monitoramento deve considerar a criticidade dos ativos, o volume de dados tratados, o potencial impacto operacional e eventuais obrigações regulatórias aplicáveis.
- Revisão Periódica de Alertas: Alertas e registros de segurança devem ser revisados periodicamente pela área de Tecnologia, que adotará as medidas necessárias para

investigação, contenção e tratamento de riscos identificados, acionando o processo de Resposta a Incidentes quando pertinente.

- **Proteção por Ferramentas e Controles Técnicos Adequados:** O GRUPO AZ poderá utilizar ferramentas de monitoramento, firewall gerenciado, soluções de detecção de ameaças, EDR e recursos nativos de nuvem ou de infraestrutura para apoiar a visualização, análise e interpretação dos eventos monitorados.
- **Privacidade e Minimização:** O monitoramento observará os princípios de finalidade, necessidade, minimização e proporcionalidade, garantindo que o tratamento de dados pessoais seja limitado ao indispensável para fins de segurança, em conformidade com a LGPD e com a Política de Governança de Dados Pessoais.
- **Responsabilidades Claras:** A área de Tecnologia é responsável pela operação e manutenção do monitoramento, enquanto o DPO deve ser acionado sempre que as informações monitoradas indicarem possível impacto a dados pessoais ou risco relevante ao titular. Gestores devem apoiar o cumprimento das diretrizes pelos membros de suas equipes.

6.11. Política de Criptografia

Na medida do possível, a proteção da confidencialidade, integridade e disponibilidade de dados poderá ser realizada através de criptografia.

Todos os dados armazenados na cloud escolhida e contratada pelo GRUPO AZ devem ser criptografados de acordo com padrões seguros.

O gerenciamento de chaves criptográficas deve ser realizado de acordo com as melhores práticas de segurança.

O GRUPO AZ atuará sempre para **não** precisar armazenar senhas em texto puro.

Acessos a dados criptografados devem ser restritos às pessoas que precisam do acesso, com base, pelo menos, nas suas funções e responsabilidades.

6.12. Política de Desenvolvimento Seguro

6.12.1. Padronização

Podem ser adotados padrões de escrita e revisão de código para melhor desempenho dessas atividades.

6.12.2. Design Seguro

6.12.2.1. Arquitetura

A arquitetura deve ser planejada para segurança das informações, com segmentação de redes sempre que apropriado, firewalls e zonas de confiança.

6.12.2.2. Criptografia

Sempre que possível, os dados devem ser criptografados. Em se tratando de senhas, elas devem ser armazenadas somente depois de criptografadas.

6.12.2.3. Controles de Acesso

As políticas de acesso devem ser elaboradas com base nas funções dos usuários.

6.12.3. Validação de Entradas

Devem ser gerenciadas as origens de entradas de vulnerabilidades como injeção de SQL, XSS e CSRF.

6.12.4. Gerenciamento de Sessões

Sempre que for feita a utilização de sessões, devem ser implementadas sessões seguras.

6.12.5. Controle de Acesso a APIs e Endpoints

Deve ser verificado se as APIs e endpoints expostos estão protegidos adequadamente para que apenas as operações permitidas sejam acessíveis.

6.12.6. Tratamento de Erros

Deve ser evitado o vazamento de informações sensíveis em mensagens de erro, o ideal é exibir mensagens de erro genéricas e sem detalhes técnicos ou informações específicas do sistema.

6.12.7. Testes de Segurança

Devem ser realizados, no mínimo, anualmente, ou sempre que necessário:

6.12.7.1. Testes de Unidade e Integração

Verificação do código para avaliar se atende aos requisitos de segurança.

6.12.7.2. Testes de Penetração

Verificação da resistência da plataforma a ataques. Os achados de testes de penetração devem ser tratados como vulnerabilidades e corrigidos e revalidados conforme a Política de Gestão de Vulnerabilidades.

6.12.7.3. Testes de Estresse

Verificação do desempenho sob carga.

6.12.8. Revisão de Código

Todos os commits devem passar por revisão de código.

6.12.8.1. Criação de Pull Requests (PRs)

Cada alteração do código deve ser realizada em um branch separado. Ao finalizar uma funcionalidade ou correção, deve ser criado um PR para revisão.

6.12.8.2. Revisão por Pares

O responsável pela área de Tecnologia irá implementar sistemas de revisão por pares para revisão do PR.

Checklist da Revisão: a revisão deve contemplar, pelo menos, os seguintes itens:

- Segurança: devem ser verificadas as vulnerabilidades conhecidas.
- Lógica do Negócio: deve ser confirmada se a funcionalidade está correta.
- Performance: deve ser avaliado o impacto no desempenho.
- Testes Unitários: deve ser verificado se os testes foram escritos e rodados.

Rotatividade de revisores: deve ser evitado que as mesmas pessoas revisem o código repetidamente, sendo recomendável que haja pelo menos duas pessoas revisando o código.

Feedback: convém a manutenção de registro das revisões realizadas e dos feedbacks dados/recebidos.

Acompanhamento: convém que as correções feitas após o feedback sejam acompanhadas e registradas.

6.12.8.3. Revisão por Ferramentas de Análise Estática e Linters

Podem ser utilizadas ferramentas homologadas para realização de análise estatística para:

- Verificar o código-fonte ou o código compilado em busca de falhas semânticas, vulnerabilidades de segurança e más práticas; e
- Verificar a conformidade do código com padrões de codificação e boas práticas.

6.12.8.4. Testes Automatizados

Poderão ser implementados testes específicos para segurança no desenvolvimento para detecção de vulnerabilidades antes da implantação.

6.12.8.5. Aprovação

Após a revisão e correções (se necessário), o PR é aprovado e mesclado no branch principal.

6.12.9. Implantação Segura

Os ambientes de produção devem ser configurados com segurança para evitar perdas de atributos básicos de segurança da informação: confidencialidade, integridade e disponibilidade:

6.12.9.1. Firewalls

O tráfego desnecessário deve ser restringido.

Os logs e eventos de segurança devem ser monitorados.

6.12.9.2. Implantação Automatizada

Deve ser configurado um pipeline seguro de CI/CD para implantar automaticamente o código revisado no ambiente de produção, através dos seguintes critérios:

- Revisão do código-fonte da automação por ferramentas de análise estática e linters
- Revisão do código por linters para verificação da conformidade do código com padrões de codificação
- Distinção de identidades de operadores e identidades de bots, atribuição de credenciais exclusivas para cada bot e restrição de acesso apenas ao necessário para a tarefa
- Armazenamento de logs de forma segura e forense, garantindo a sua completude e integridade para investigações futuras

6.13. Política de Gestão e Proteção de Endpoints

Devem ser estabelecidas diretrizes, controles e procedimentos para proteção de todos os endpoints utilizados no Grupo AZ, garantindo conformidade com LGPD, ISO 27001, NIST e CIS Controls. Esta política abrange:

- Notebooks, desktops e tablets corporativos;
- Dispositivos pessoais utilizados sob regime BYOD;
- Servidores locais e máquinas virtuais em nuvem;
- Softwares de proteção, monitoramento e inventário instalados nos endpoints.

Cada endpoint deve possuir:

Controle	Exigência	Norma aplicável
Antivírus / Antimalware	Atualização automática diária	CIS Control 10
Firewall local	Ativado e bloqueio de portas inseguras	NIST SP 800-171
EDR	Deteção e resposta em tempo real	ISO 27002 8.16
Atualizações	Patches críticos aplicados de forma segura e em tempo adequado	CIS v8 – 7.2

Regras básicas:

- É proibida a instalação de softwares não autorizados.

- Dispositivos devem operar com conta sem privilégios administrativos.
- Todo endpoint deve ser registrado no inventário de ativos.
- É vedado armazenar dados pessoais em pastas locais sem criptografia.
- Backups devem ocorrer exclusivamente em repositórios corporativos.

6.13.1. Política de instalação e uso de softwares

O setor de tecnologia e a DPO são responsáveis por controlar e manter os softwares utilizados pela empresa, respeitando os direitos de propriedade intelectual.

Apenas softwares homologados e autorizados pelo setor de Tecnologia podem ser instalados nos equipamentos cedidos pela empresa e apenas os que previamente autorizados podem ser utilizados para tratamento de ativos do GRUPO AZ.

Sempre que houver compartilhamento de dados pessoais, inclusive de clientes, a DPO deverá ser envolvida na contratação, monitoramento e gestão do contrato com o fornecedor.

6.14. Política de Backups

- Os ativos devem ser salvos na nuvem contratada pelo GRUPO AZ;
- Os **AZTechs** não estão autorizados a utilizar recursos (pen drive, cloud etc.) para efetuar backup, salvo prévia e expressa autorização da pessoa gestora de Tecnologia.
- Deverá ser mantido controle rigoroso de acesso ao backup;
- O tempo de retenção deverá observar as necessidades da empresa, as especificidades do negócio, necessidades do cliente do GRUPO AZ e a legislação aplicável;
- A realização e manutenção de backup é uma atribuição exclusiva do setor de Tecnologia.

6.15. Política de Retenção e descarte de dados

O GRUPO AZ deverá garantir a manutenção de uma política específica com procedimentos adequados para garantir que:

- As informações impressas e de conteúdo sensível serão trituradas e ou incineradas.
- As informações eletrônicas serão eliminadas de forma certificada pelo setor de Tecnologia.
- O descarte de recursos será realizado e/ou gerenciado pelo setor de Tecnologia, mediante a utilização de técnicas que garantam a eliminação definitiva dos dados e a impossibilidade de sua recuperação.

6.16. Gestão de incidentes de segurança

Todos os incidentes ou fragilidades de Segurança da Informação devem ser reportados à equipe de Tecnologia/DPO, que deve proceder ao registro, análise e tratamento.

São considerados incidentes de segurança da informação quaisquer eventos adversos de segurança, confirmados ou sob suspeita que levem ou possam levar ao comprometimento de um ou mais dos princípios básicos da segurança das informações: confidencialidade, integridade ou disponibilidade, colocando o negócio em risco.

O GRUPO AZ deve ter implementado os necessários processos para gerenciar incidentes de segurança. Qualquer incidente deve ser relatado imediatamente ao setor de Tecnologia para avaliação da ação apropriada que deve ser tomada para minimizar o impacto do incidente, através do acionamento do Plano de Gestão de Incidentes, processo formal para gestão de incidentes de segurança da informação que define responsabilidades, hierarquia no tratamento e diretrizes de resposta a incidentes, dentre outros pontos importantes.

Violações ou tentativas de violação desta **Política**, de normas ou de controles de segurança da informação, intencionais ou não, são consideradas incidentes de segurança.

6.17. Política de Gestão de Vulnerabilidades

O GRUPO AZ estabelece diretrizes para identificação, análise, priorização e tratamento de vulnerabilidades presentes nos sistemas, aplicações, infraestrutura e ativos tecnológicos utilizados na prestação de serviços. Esta política reflete as práticas atuais da organização e orienta sua evolução contínua, conforme boas práticas de segurança da informação.

O GRUPO AZ realiza avaliações periódicas de vulnerabilidades, utilizando principalmente os recursos oferecidos pelo EDR Kaspersky, configurado para detectar falhas de segurança conhecidas, comportamentos suspeitos e fragilidades em ativos internos e externos.

São realizadas varreduras automatizadas em ativos institucionais internos. Conforme a maturidade do GRUPO AZ evolua, poderão ser agregadas ferramentas compatíveis com SCAP para ampliar a capacidade de análise.

As prioridades de correção serão comunicadas de maneira transparente às equipes responsáveis, incluindo informações detalhadas sobre os riscos associados a cada vulnerabilidade, conforme sua classificação.

As vulnerabilidades serão classificadas de acordo com sua criticidade e impacto, estabelecendo prioridades para a sua correção, através de ferramentas de varredura automatizada, testes de penetração e revisões de código para identificar e classificar as vulnerabilidades.

Após serem avaliadas de acordo com o impacto e criticidade, as vulnerabilidades podem ser:

- **Baixo risco:** questões menores de segurança com um impacto limitado nas operações. As correções serão programadas e implementadas de acordo com a disponibilidade de recursos. A correção deve ser feita na próxima atualização planejada ou ciclo de manutenção.

- **Médio risco:** nível moderado de criticidade e impacto. Podem incluir falhas que, se exploradas, podem resultar em consequências significativas, mas não são iminentes. Devem ser implementadas correções em um prazo razoável, considerando a gravidade moderada das vulnerabilidades. Deve ser programada a correção em uma janela de manutenção apropriada para minimizar o impacto nas operações.
- **Alto risco:** exigem correção imediata, devendo ser implementadas medidas de mitigação temporárias, se necessário, enquanto as correções permanentes são preparadas, com um processo de correção urgente e que pode envolver várias partes relevantes.

Atualmente, o GRUPO AZ não opera com gestão automatizada de patches.

As atualizações são aplicadas de forma reativa, considerando que determinadas atualizações podem afetar serviços críticos em produção.

A gestão de mudanças deve abordar:

- avaliação prévia do impacto do patch;
- janela adequada para atualização;
- rollback quando necessário;
- documentação da mudança aplicada.

Devem ser realizados testes de simulação regulares para avaliar a prontidão e eficácia dos procedimentos de resposta a incidentes, sendo documentados e analisados os resultados, aprimorando continuamente os processos de segurança.

6.18. Política de Proteção contra códigos maliciosos

O GRUPO AZ adota medidas técnicas, organizacionais e operacionais para prevenir, detectar e responder a códigos maliciosos (malware), abrangendo vírus, worms, trojans, ransomware, spyware, adware, rootkits, scripts maliciosos e qualquer outro tipo de software potencialmente nocivo.

As diretrizes abaixo devem ser observadas em todos os ambientes, sistemas, dispositivos e operações tecnológicas do GRUPO AZ.

1. Infraestrutura Segura e Controles Tecnológicos Obrigatórios

A nuvem contratada e o firewall gerenciado pelo GRUPO AZ devem garantir a possibilidade de implementação dos seguintes controles:

- prevenção, detecção, correção e erradicação de códigos maliciosos;
- bloqueio proativo de ameaças conhecidas e desconhecidas;
- inspeção de tráfego;
- filtros de reputação e sandboxing, quando aplicável;

- integração com sistemas de monitoramento e resposta.

O GRUPO AZ mantém solução antimalware instalada em seus ativos de informação, atualmente por meio de EDR Kaspersky, gerenciado de forma centralizada.

Todos os dispositivos corporativos devem utilizar a solução homologada pelo setor de Tecnologia. O gerenciamento inclui monitoramento contínuo, verificação de alertas, correção de incidentes e manutenção da integridade dos agentes instalados.

Os sistemas operacionais e aplicações devem ter habilitados controles nativos de segurança.

6.19. Política de Prevenção e detecção de intrusão

O GRUPO AZ adota medidas proporcionais ao seu ambiente tecnológico para prevenir, detectar e responder a tentativas de intrusão e acessos não autorizados aos sistemas corporativos. Esta política reflete os controles atualmente implementados e direciona a evolução futura das práticas de segurança.

Os sistemas de informação do GRUPO AZ que estão expostos à Internet – como servidores, serviços Cloud, APIs e aplicações – são protegidos por:

- firewall gerenciado, responsável por filtrar acessos, bloquear tráfego indevido e registrar eventos relevantes;
- monitoramento de desempenho e comportamento via Zabbix, capaz de identificar anomalias operacionais que possam indicar falhas ou comportamentos incomuns;
- EDR Kaspersky, que complementa a proteção com detecção de comportamentos suspeitos em endpoints.

Sempre que detectados eventos potencialmente graves ou tentativas externas de acesso indevido, o setor de Tecnologia deve realizar análise e registrar o ocorrido, tomando as medidas cabíveis.

Ferramentas adicionais poderão ser contratadas se houver necessidade ou evolução do ambiente tecnológico.

6.20. Política de Treinamento e Conscientização

Esta **Política** e as normas e padrões de segurança gerais devem ser amplamente divulgadas no processo de admissão e integração de novos colaboradores.

Programas de conscientização, divulgação e reciclagem do conhecimento sobre esta **Política** e para aprimoramento da cultura da segurança da informação e da proteção cibernética devem ser estabelecidos e praticados regularmente para garantir que todos os colaboradores e terceiros conheçam as diretrizes e responsabilidades relacionadas à segurança das informações.

Além dos treinamentos gerais, serão promovidos treinamentos específicos para funções críticas, como equipes de Tecnologia, Segurança da Informação, Privacidade e gestores de áreas com tratamento intensivo de dados, alinhados às suas atribuições.

7. AUDITORIA E MONITORAMENTO

O GRUPO AZ reserva-se o direito de auditar e monitorar qualquer dispositivo, processo e procedimento relacionado às suas atividades que impactam os seus negócios, de acordo com esta **Política** para monitorar de forma contínua a adesão dos colaboradores às regras e procedimentos da empresa, bem como para detectar atividades suspeitas nos sistemas e redes.

Poderão ser realizadas auditorias internas e externas, inclusive de certificação de frameworks de segurança, sendo documentados e analisados os resultados, aprimorando continuamente os processos de segurança, incluindo a análise de:

- Monitoramento dessa Política;
- Nível de usuário e/ou acesso em nível de sistema a qualquer computação ou comunicação do GRUPO AZ;
- Nível de acesso às informações que possam ser produzidas, transmitidas ou armazenadas em equipamentos ou instalações do GRUPO AZ; e
- Acesso às áreas de trabalho do GRUPO AZ.

Todas as auditorias realizadas pelo GRUPO AZ observarão as regras da LGPD.

8. GESTÃO DE CONSEQUÊNCIAS

A atuação em desacordo com essa Política será considerada falta grave, motivo pelo qual será causa de apuração de responsabilidade do infrator, através da competente investigação interna. Feita a investigação, no limite, o agente infrator poderá sofrer penalidades administrativas e contratuais, até, se for o caso, a rescisão do contrato vigente entre as partes, sem prejuízo do pagamento das perdas e danos porventura infringidas no GRUPO AZ.

9. INDICADORES DE SEGURANÇA DA INFORMAÇÃO

Esta Política inclui uma série de indicadores chave que foram cuidadosamente selecionados para fornecer uma visão abrangente da segurança da informação em nossa organização, conforme Anexo.

10. ATUALIZAÇÃO DESTA POLÍTICA

Sempre que esta Política sofrer alterações, as alterações serão objeto de comunicação para todas as partes potencialmente interessadas nas suas disposições.

11. VIGÊNCIA

Esta **Política**, aprovada pelo GRUPO AZ, tem vigência imediata e será revisada no período máximo de um 1 (um) ano ou havendo necessidade anterior, o que for menor, para que permaneça sempre atualizada.

ANEXO A - INDICADORES DE SEGURANÇA DA INFORMAÇÃO

Os indicadores abaixo têm por objetivo permitir o monitoramento contínuo da eficácia dos controles de Segurança da Informação e Segurança Cibernética do GRUPO AZ, bem como apoiar a tomada de decisão, priorização de ações e melhoria contínua do Sistema de Gestão.

Sempre que possível, os indicadores deverão conter, no mínimo:

- Definição do indicador;
- Fórmula de cálculo;
- Fonte de dados;
- Periodicidade de apuração;
Responsável pelo monitoramento; e
- Meta ou faixa de controle (quando aplicável).

1. Governança e Conformidade

1.1. Percentual de Políticas e Normas Revisadas no Prazo

Mede a proporção de políticas, normas e procedimentos de segurança da informação e privacidade revisados dentro da periodicidade definida para garantir que a documentação de segurança permaneça atualizada e alinhada ao ambiente regulatório e de riscos.

1.2. Número de Não Conformidades Identificadas em Auditorias

Contabiliza as não conformidades apontadas em auditorias internas e externas relacionadas à segurança da informação, privacidade e controles tecnológicos para monitorar aderência às políticas e identificar áreas que demandam priorização de correções.

1.3. Percentual de Ações de Planos de Ação Concluídas no Prazo

Mede o cumprimento dos planos de ação decorrentes de auditorias, incidentes, avaliações de risco e avaliações de vulnerabilidades para assegurar efetividade e tempestividade na correção de falhas.

2. Gestão de Acessos e Contas

2.1. Tempo Médio de Revogação de Acesso após Desligamento

Mede o intervalo médio entre a data/hora do desligamento de um AZTech e o bloqueio efetivo de seus acessos para reduzir o risco de acessos indevidos após o término do vínculo.

2.2. Percentual de Contas com Autenticação Multifator (MFA) Ativada em Sistemas Críticos

Mede a proporção de contas de usuário com MFA habilitado nos sistemas classificados como críticos para fortalecer os mecanismos de autenticação e reduzir risco de comprometimento de credenciais.

2.3. Número de Contas com Privilégios Elevados Ativas

Contabiliza contas administrativas, de superusuário ou com acessos privilegiados ativos para apoiar a revisão periódica de privilégios e aplicação do princípio do mínimo acesso.

3. Incidentes de Segurança da Informação e de Dados Pessoais

3.1. Número de Incidentes de Segurança Registrados

Mede a quantidade total de incidentes de segurança reportados, possibilitando identificar padrões, evoluções e áreas que demandam fortalecimento de controles.

3.2. Percentual de Incidentes Classificados como de Alto Impacto

Avalia a proporção de incidentes classificados como de alta severidade entre o total reportado, evidenciando a criticidade das ocorrências e o impacto potencial no negócio.

3.3. Tempo Médio de Resposta e Contenção de Incidentes (MTTR – Mean Time to Respond)

Mede o intervalo médio entre a detecção de um incidente e sua contenção ou neutralização, demonstrando a agilidade operacional na mitigação de danos e na restauração da normalidade.

3.4. Número de Incidentes com Notificação a Clientes, Parceiros ou Autoridade (ANPD)

Registra a quantidade de eventos que exigiram comunicação formal a autoridades ou clientes, refletindo a gravidade e a materialidade das ocorrências.

4. Vulnerabilidades, Patches e Proteção contra Códigos Maliciosos

4.1. Número de Vulnerabilidades Identificadas por Criticidade

Mede a quantidade de vulnerabilidades identificadas nos ativos tecnológicos, classificadas por criticidade, permitindo compreender a exposição a riscos e priorizar remediações.

4.2. Percentual de Vulnerabilidades Críticas Corrigidas dentro do Prazo Definido (SLA)

Avalia a efetividade do processo de correção ao mensurar a proporção de vulnerabilidades críticas tratadas dentro do prazo definido, reduzindo riscos de exploração.

4.3. Número de Eventos de Detecção de Códigos Maliciosos

Monitora a incidência de códigos maliciosos detectados pela solução de EDR, permitindo avaliar a efetividade dos controles preventivos e identificar tendências de ameaças.

4.4. Percentual de Equipamentos com Antimalware Ativo e Atualizado

Mede a cobertura e atualização do software antimalware nos dispositivos corporativos, assegurando que todos operem com proteção adequada e atual contra ameaças.

5. Treinamento, Conscientização e Cultura de Segurança

5.1. Percentual de Colaboradores com Treinamento Obrigatório Atualizado

Avalia o nível de maturidade organizacional ao medir a proporção de AZTechs que concluíram os treinamentos obrigatórios dentro do período previsto, garantindo conhecimento atualizado sobre segurança.

5.2. Taxa de Cliques em Simulações de Phishing

Mede a suscetibilidade dos usuários a ataques de engenharia social ao identificar a porcentagem de colaboradores que interagem com mensagens falsas enviadas como teste, permitindo direcionar ações educativas.

5.3. Número de Comunicações e Ações de Conscientização Realizadas

Registra a quantidade de iniciativas de sensibilização realizadas, como campanhas, comunicados e workshops, demonstrando o esforço contínuo de fortalecimento da cultura de segurança.

6. Continuidade, Disponibilidade e Resiliência

6.1. Disponibilidade de Sistemas Críticos (%)

Mede o percentual de tempo em que os sistemas essenciais permaneceram operacionais, garantindo continuidade das atividades e redução do risco de indisponibilidades que afetem o negócio.

6.2. Número de Testes de Plano de Continuidade/Recuperação Realizados

Avalia a prontidão da organização ao registrar a quantidade de exercícios de recuperação, testes de contingência e simulações realizados, assegurando capacidade de resposta a falhas.

6.3. Tempo Médio de Recuperação em Testes de Continuidade (RTO Praticado)

Mede o tempo efetivo necessário para restaurar serviços após incidentes, permitindo comparar desempenho real com objetivos de recuperação e avaliar a resiliência operacional.

7. Proteção de Dados Pessoais e Privacidade

Conforme definido na Política de Governança de Dados Pessoais.

8. Auditoria, Monitoramento e Gestão de Consequências

8.1. Número de Auditorias de Segurança e Privacidade Realizadas no Período

Mede o volume de auditorias internas e externas executadas, demonstrando o nível de controle e acompanhamento das práticas de segurança e conformidade.

8.2. Número de Desvios Reincidentes Identificados em Auditoria ou Monitoramento

Avalia a eficácia das correções implementadas ao registrar quantas não conformidades se repetiram após tratativas, evidenciando falhas persistentes.

8.3. Número de Medidas Disciplinares Relacionadas a Quebra de Política de Segurança e Privacidade

Mede a quantidade de ações disciplinares decorrentes de descumprimento das políticas de segurança, permitindo monitorar engajamento, comportamento e aderência às normas.



(04.12.2025) Política de Seguranca Cibernetica e das Informacoes.pdf

Código do documento: JDAY-9XUL-U3R6-SHXY

**Autenticação Eletrônica**

Valide em <https://app-sign.efcaz.com.br/flowbee-pub/#!/validar/JDAY-9XUL-U3R6-SHXY>

Ou digite o código: JDAY-9XUL-U3R6-SHXY

Assinado em conformidade à Medida Provisória nº 2.200-2/2001 e Lei 14.063/2020.

Assinaturas



Eletrônica

elias.mendonca@azi.com.br

e*****ca@azi.com.br

Gestor

elias.mendonca@azi.com.br



Eletrônica

Paulo Cesar Pizzo Sorato

p*****to@azi.com.br

Representante Legal

Paulo C. P. Sorato



Registro eventos

05/12/2025 20:19

elias.mendonca@azi.com.br

Assinou como Gestor. Documento: 887.***.***.**.

Data nascimento: 10/02/1980. Email: e*****ca@azi.com.br. IP: 200.241.189.50. Localização: Cidade: null, Estado: null. Nível de segurança: Validado por código único enviado por e-mail.

RUBRICA

e.

05/12/2025 20:51

Paulo Cesar Pizzo Sorato

Assinou como Representante Legal. Documento: 050.***.***.**.

Data nascimento: 28/04/1963. Email: p*****to@azi.com.br. IP: 168.227.210.147. Localização: Cidade: Ponta Porã, Estado: Mato Grosso do Sul. Nível de segurança: Validado por código único enviado por e-mail.

RUBRICA

P.C.P.S.

Hash do documento original: 08aa611c02b38c78694504aa6154eb6085f531169138a65d82b7d6d84b5dd49d

Hash do documento assinado: 63b8109bc2b73c0555b242fecde8fa5ecc61568e50c581de45352afa73d5dc6c
